

CYBER SECURITY RISK MANAGEMENT INTERNSHIP SUMMARY

By: John Gabriel

CYBERSECURITY

Red Team

- Application risk assessment
- Penetration testing
- Vulnerability assessment
- Log file & database checks

Blue Team (SOC)

- First line of defense (24/7)
- Traffic monitoring & remediation
- SIEM tools & log analysis
- Password management

Governance Team

- Creating policies & guidelines
- Vendor management
- User access requests
- Change management

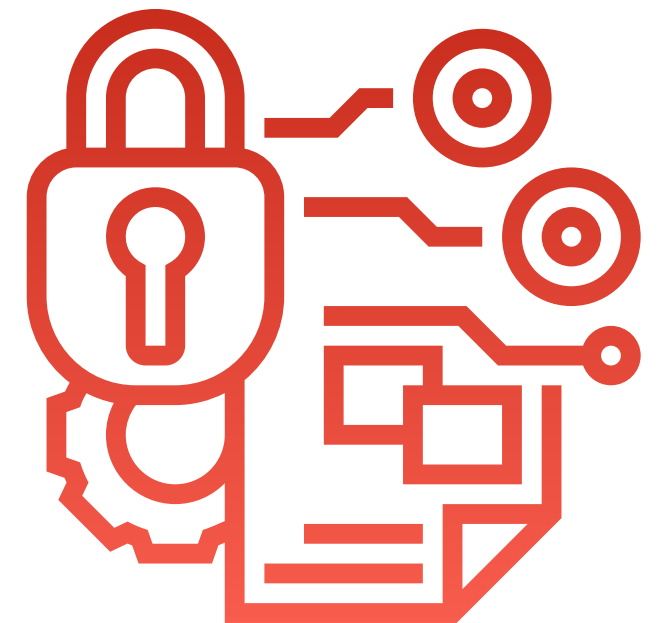
CIA TRIAD

Confidentiality, Integrity, and Availability

- **Confidentiality:** Protects sensitive information from unauthorized access. Techniques include encryption, access controls, and strong authentication measures.
- **Integrity:** Ensures data accuracy and consistency throughout its lifecycle. This involves checksums, hashes, data validation, and maintaining audit trails.
- **Availability:** Guarantees that information is accessible to authorized users when needed. Strategies include redundancy, failover systems, regular maintenance, and disaster recovery planning.

DATA SAFETY

- **Masking** – Hides sensitive data (e.g., shows only last 4 digits of a credit card).
- **Encryption** – Secures data by converting it into unreadable code:
 - **Symmetric**: Same key for encryption & decryption.
 - **Asymmetric**: Public key encrypts, private key decrypts.
 - **Hybrid**: Combines both for efficiency & security.
- **Hashing** – One-way algorithm producing a fixed-length output to verify data integrity.
- **Encoding** – Converts data into another format for compatibility (not for security).



OSI MODEL

Open Systems Interconnection

- **Physical Layer** – Transfers raw bits (0s and 1s) over physical media (cables, hubs).
- **Data Link Layer** – Creates frames, handles MAC addresses, and error detection (switches, bridges).
- **Network Layer** – Routes packets between devices/networks using IP addresses (routers, protocols like IP, ICMP).
- **Transport Layer** – Breaks data into segments, ensures correct delivery using TCP (reliable) or UDP (fast).
- **Session Layer** – Starts, manages, and ends communication sessions between applications.
- **Presentation Layer** – Formats, encrypts, and compresses data for compatibility between systems.
- **Application Layer** – Directly interacts with the user, providing services like HTTP (web), SMTP (email), DNS (domain names).

Three-Way Handshake

Process to establish a reliable TCP connection between two devices:

SYN – Client sends a synchronization request to start a connection.

SYN-ACK – Server acknowledges the request and sends its own synchronization signal.

ACK – Client acknowledges the server's response, and the connection is established.

Purpose: Ensures both devices are ready for data transfer and agree on communication parameters.



TCP/UDP

TCP (Transmission Control Protocol)

- Connection-oriented, reliable communication.
- Ensures all data arrives correctly and in order.
- Uses 3-Way Handshake to establish a connection.

UDP (User Datagram Protocol)

- Connectionless, fast communication.
- No guarantee of delivery or order.
- Ideal for streaming, online games, and VoIP.

IP (Internet Protocol)

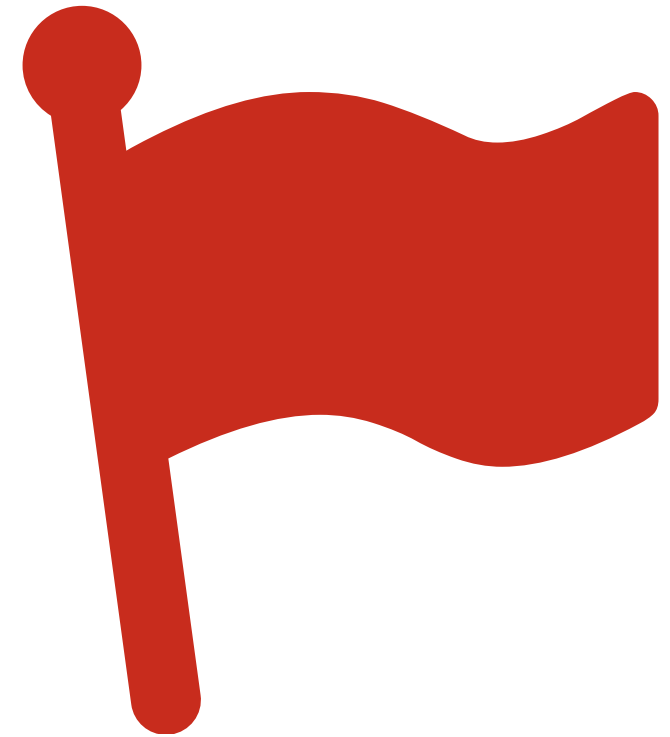
- Routes data packets between devices and networks.
- Uses IP addresses to identify source and destination.
- Works with both TCP and UDP to deliver data.

TCP FLAGS

Control communication in TCP segments

- **SYN (Synchronization)**: Initiates a connection.
- **ACK (Acknowledgment)**: Confirms receipt of data.
- **PSH (Push)**: Sends data immediately, bypassing buffers.
- **URG (Urgent)**: Marks urgent data for priority delivery.
- **FIN (Finish)**: Gracefully terminates a connection.
- **RST (Reset)**: Immediately resets or aborts a connection.

Purpose: Each flag controls specific aspects of TCP communication to manage connection setup, data transfer, and termination.



PORTS OVERVIEW

What is a Port?

A port is a virtual endpoint that directs network traffic to specific applications or services on a computer.

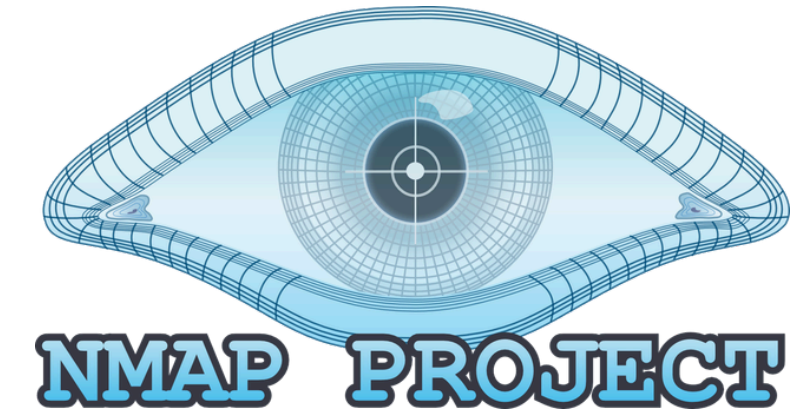
Port Categories:

- **Well-Known / System Ports (0–1023):**
Reserved for widely used system services and applications.
- **Registered Ports (1024–49151):** Used by less common applications or services requiring specific ports.
- **Dynamic / Private Ports (49152–65535):**
Temporary, short-lived connections; not assigned to specific services.

Common Ports & Services:

- 20: FTP Data Transfer** – Upload/download files
- 21: FTP Command** – Controls FTP session
- 22: SSH** – Secure remote access
- 23: Telnet** – Unencrypted remote login
- 25: SMTP** – Send/relay emails
- 53: DNS** – Domain Name System (translates domains to IPs)
- 80: HTTP** – Web traffic (unencrypted)
- 161: SNMP** – Network management & monitoring
- 443: HTTPS** – Secure web traffic

NMAP



Network Scanning Tool

Purpose: Scans targets to discover open ports, running services, and versions.

Target Specification: Allows detailed detection of services and their versions.

Use in Security: Identifies potential vulnerabilities by mapping network services.

Port Scanning Basics (Status):

- **Open:** Port actively accepting connections; potential entry point for attacks.
- **Closed:** No service listening; not currently vulnerable.
- **Filtered:** Firewall or security device blocks access; cannot confirm if open.
- **Unfiltered:** Accessible but Nmap can't determine if open or closed; may need additional scan types.
- **Open|Filtered:** Cannot determine if the port is open or filtered.
- **Closed|Filtered:** Cannot determine if the port is closed or filtered; mainly used in idle scans.

Basic Nmap Scans

- **-p [port ranges]** – Scan only specific ports on a target.
- **-sS (TCP SYN Scan)** – Sends SYN packets; detects open ports without completing full handshake.
- **-sT (Connect Scan)** – Default TCP scan; completes full connection to detect open ports.
- **-sU (UDP Scan)** – Scans UDP ports to check for services without TCP connections.
- **-sA (ACK Scan)** – Maps firewall rules; identifies filtered or unfiltered ports.
- **-sF (FIN Scan)** – Sends FIN packets; helps detect stealthy open/closed ports.
- **-sL (List Scan)** – Lists hosts in the network without sending packets to them.
- **-Pn** – Disables ping; treats all hosts as alive for scanning.
- **-T4** – Adjusts scan speed for faster results.
- **-A (Aggressive Scan)** – Combines OS detection, version detection, script scanning, and traceroute.
- **--script=default** – Runs default Nmap scripts to gather more info about services.

OWASP TOP 10



OWASP
Open Web Application
Security Project

- **A01:2021 Broken Access Control** – Users can access unauthorized resources or actions.
- **A02:2021 Cryptographic Failures** – Weak or missing encryption risks sensitive data.
- **A03:2021 Injection** – Attackers insert malicious commands (e.g., SQL, OS commands).
- **A04:2021 Insecure Design** – Security not considered during application design.
- **A05:2021 Security Misconfiguration** – Default credentials, open ports, or improper settings.
- **A06:2021 Vulnerable & Outdated Components** – Using old libraries or frameworks with known flaws.
- **A07:2021 Identification & Authentication Failures** – Weak login, session, or credential handling.
- **A08:2021 Software & Data Integrity Failures** – Code or data can be tampered with; untrusted sources used.
- **A09:2021 Security Logging & Monitoring Failures** – Attacks go undetected due to missing logs/alerts.
- **A10:2021 Server-Side Request Forgery (SSRF)** – Attackers trick server to access internal systems.

OWASP TOP 10 Impacts

- **Broken Access Control** – Unauthorized data access, privilege escalation.
- **Cryptographic Failures** – Sensitive data exposure, identity theft.
- **Injection (e.g., SQLi)** – Data theft, modification, or deletion; system compromise.
- **Insecure Design** – Increased attack surface; exploitable application flaws.
- **Security Misconfiguration** – Unauthorized access, service disruption.
- **Vulnerable & Outdated Components** – Exploitation of known vulnerabilities; malware infection.
- **Identification & Authentication Failures** – Account takeover, session hijacking.
- **Software & Data Integrity Failures** – Tampered code/data, backdoors, unauthorized modifications.
- **Security Logging & Monitoring Failures** – Attacks go undetected; delayed response.
- **Server-Side Request Forgery (SSRF)** – Access to internal systems, sensitive data leakage.

OWASP TOP 10

Recommendations

- **Broken Access Control** – Enforce least privilege; validate access server-side.
- **Cryptographic Failures** – Use strong algorithms, enforce key rotation, secure key storage.
- **Injection** – Validate input, use parameterized queries, separate data from code.
- **Insecure Design** – Include security in design phase; threat modeling.
- **Security Misconfiguration** – Regularly review and update configurations; disable defaults.
- **Vulnerable & Outdated Components** – Patch frequently; use supported libraries.
- **Identification & Authentication Failures** – Enforce strong passwords, multi-factor authentication (MFA).
- **Software & Data Integrity Failures** – Validate code/data from trusted sources, use hashing/signatures.
- **Security Logging & Monitoring Failures** – Implement proper logging, alerting, and monitoring.
- **Server-Side Request Forgery (SSRF)** – Validate inputs, allowlist domains, block private/internal IP access.

BURP SUITE

Web Application Security Tool (Basics)

Purpose: Identify vulnerabilities in web applications through testing and scanning.

Main Functions:

- **Proxy:** Intercepts and inspects HTTP/HTTPS requests and responses.
- **Scanner:** Automatically detects common vulnerabilities (e.g., SQLi, XSS).
- **Intruder:** Automates customized attacks to test input fields.
- **Repeater:** Allows manual modification and replaying of requests to test behavior.
- **Logger:** Keeps a record of all requests and responses for analysis.

Use in Security Testing: Helps red teams or penetration testers identify weaknesses before attackers exploit them.



SQL INJECTION

Definition: Attack where malicious SQL commands are inserted into input fields to manipulate the database.

Impact: Unauthorized data access, modification, deletion; can expose sensitive user information like passwords or credit card details.

Example: `SELECT * FROM users WHERE username = 'admin' AND password = 'password';` → attacker modifies input to bypass authentication.

Prevention: Use parameterized queries, validate and sanitize user inputs, separate code from data.

Blind SQL Injection (Blind SQLi)

Definition: SQLi where the application does not display database errors or output. Attackers infer database information based on response behavior or timing.

Types:

- **Boolean-based:** Observes changes in web page content based on true/false queries.
- **Time-based:** Measures response delays to infer database values.

Impact: Same as SQLi, but harder to detect.

Prevention: Validate inputs, use prepared statements, restrict database privileges.



XSS (Cross-site Scripting)

Definition: A vulnerability that allows an attacker to inject malicious scripts into web pages viewed by other users.

Types of XSS Attacks:

1. **Stored XSS:** Malicious script is permanently stored on the server (e.g., in a database).
2. **Reflected XSS:** Malicious script is reflected off the web server, often through URL parameters.
3. **DOM-based XSS:** The vulnerability exists in the client-side code, where the script executes based on user input without interacting with the server.

Impact:

- Data Theft: Steals sensitive user data (cookies, session tokens).
- Session Hijacking: Takes control of a user's session.
- Defacement: Alters content on the web page.
- Malware Distribution: Distributes malicious files or redirects users to harmful sites.

{ JavaScript }

Recommendations:

- Input Validation & Sanitization: Validate and sanitize user inputs.
- Content Security Policy (CSP): Implement a CSP to block malicious content.
- Escaping Data: Ensure any data inserted into the HTML is properly escaped.
- HttpOnly & Secure Cookies: Use secure cookie flags to mitigate session theft.

PENETRATION TEST REPORT

- How to make a professional Report.
- Proper formatting.
- Step by step process
- Experience in making a report.
- Tested technical skills and obtained knowledge.

PENETRATION TESTING REPORT

WEB APPLICATION &
NETWORK MAPPING (NMAP)
ASSESSMENT

FOR

(INTERNSHIP)

8-12-2025 - 8-14-2025